Auditoría de Exposición Digital

Análisis externo de superficie y recomendaciones

Riesgo Tecnológico — Consultoría independiente en gobierno del riesgo tecnológico y cumplimiento normativo. [www.riesgotecnologico.com]

Aviso de confidencialidad

Este documento es una versión pública de un informe de auditoría entregado a una organización cliente. Por motivos de confidencialidad, se han omitido o generalizado los identificadores del entorno auditado, incluidos dominios, direcciones, nombres de activos y cualquier otra referencia que pudiera permitir la identificación del destinatario original. También se han eliminado las referencias temporales del análisis.

Se preservan la lógica técnica, la metodología empleada y la naturaleza de los hallazgos. Las evidencias incluidas a modo ilustrativo han sido sanitizadas de forma tal que conservan su valor demostrativo sin exponer información sensible del entorno real.

Los hallazgos descritos corresponden al estado de exposición observado al momento de la auditoría. Las condiciones relevantes fueron posteriormente abordadas por la organización auditada, por lo que este documento no refleja el estado actual de su infraestructura ni debe interpretarse como una descripción vigente de la misma.

Clasificación del documento

Informe técnico de auditoría adaptado para difusión profesional.

1. Resumen Ejecutivo

Este informe documenta los resultados de una auditoría externa de exposición digital realizada sobre la infraestructura accesible desde internet de una organización cliente. El trabajo se llevó a cabo sin interacción intrusiva, utilizando técnicas de reconocimiento pasivo, correlación de fuentes abiertas y escaneo controlado de servicios publicados.

El análisis identificó una superficie de exposición más amplia que la justificable por la operación actual de la organización. Se detectaron activos publicados sin función operativa evidente, servicios de

administración accesibles desde internet sin restricciones de origen, y fugas de información en respuestas de servicios que facilitan el reconocimiento de tecnologías y versiones en uso. La correlación entre estos elementos permitió reconstruir parcialmente la arquitectura expuesta desde la perspectiva de un observador externo.

No se identificaron indicadores de compromiso activo durante el período de análisis. Sin embargo, las condiciones observadas configuran un escenario favorable tanto a reconocimiento automatizado como a ataque dirigido, y algunas de ellas tienen implicancias directas en materia de protección de datos y trazabilidad regulatoria.

Valoración de riesgo agregado: medio-alto. La severidad no se concentra en un hallazgo crítico aislado, sino en la combinación de condiciones de severidad baja y media que, consideradas en conjunto, reducen significativamente el esfuerzo requerido por un tercero para comprender y potencialmente comprometer el entorno.

Acciones prioritarias. El informe recomienda, como medidas de aplicación inmediata, la despublicación de los activos sin función operativa identificados durante la auditoría, la restricción por origen de los paneles administrativos expuestos, y la revisión del inventario de activos publicados con un criterio unificado. Estas acciones, detalladas en la sección 6, abordan la mayor parte del riesgo identificado con un esfuerzo de implementación acotado.

2. Objetivo y Alcance

Objetivo

La auditoría tuvo por objeto caracterizar la exposición digital de la organización desde la perspectiva de un observador externo no autorizado, identificando los activos y servicios accesibles desde internet y evaluando en qué medida la información pública disponible permite inferir estructura, tecnologías y comportamiento operativo del entorno.

En términos operativos, el trabajo se orientó a tres cuestiones:

- Qué activos y servicios de la organización son efectivamente alcanzables desde internet, incluyendo aquellos no documentados en canales oficiales.
- Qué configuraciones, respuestas de servicios e información residual en fuentes abiertas facilitan el reconocimiento de la infraestructura por parte de terceros.
- Qué nivel de conocimiento sobre el entorno puede construir un tercero utilizando exclusivamente información pública, sin interacción intrusiva.

Alcance

El análisis se realizó sobre el conjunto de activos expuestos públicamente asociados a la organización. El punto de partida fue el dominio corporativo principal comunicado por el cliente; a partir de ahí se realizó descubrimiento progresivo de activos relacionados mediante consulta de fuentes públicas, registros DNS, registros de transparencia de certificados y correlación de infraestructura, lo que

permitió identificar un conjunto de subdominios y servicios adicionales no declarados en el perímetro inicial.

Sobre el conjunto resultante se ejecutaron las siguientes actividades:

- Enumeración de dominios y subdominios activos, incluyendo los no referenciados en canales oficiales.
- Escaneo controlado de puertos y servicios sobre los activos identificados, con el objeto de determinar superficie de exposición, tecnologías en uso y versiones inferibles.
- Análisis de configuraciones observables desde el exterior: headers HTTP, certificados, códigos de respuesta, banners de servicios y mensajes de error.
- Recolección y correlación de información pública (OSINT) orientada a identificar relaciones entre activos, indicios de segmentación de entornos y referencias cruzadas a componentes de infraestructura.

Fuera de alcance

No formaron parte del trabajo las pruebas de explotación activa, la evaluación de infraestructura no expuesta públicamente, el análisis de código fuente o aplicaciones sin acceso público, y la revisión de controles internos de identidad, accesos y políticas organizacionales. La auditoría se limitó a observación externa y no involucró credenciales, agentes instalados ni información provista por el cliente más allá del dominio principal y la autorización formal para ejecutar el trabajo.

3. Metodología

El trabajo se realizó siguiendo un enfoque progresivo en cuatro fases, con priorización inicial de técnicas pasivas y escalamiento controlado hacia técnicas activas no intrusivas sobre los activos identificados. La metodología se apoya en prácticas establecidas para auditoría externa de superficie, tomando como referencia los lineamientos de OWASP para testing de seguridad en aplicaciones web (OWASP Testing Guide, sección de Information Gathering) y las recomendaciones de NIST SP 800-115 en lo relativo a técnicas de examinación y análisis del entorno objetivo.

Fase 1 — Reconocimiento pasivo (OSINT). Recolección de información sobre el entorno de la organización sin interacción directa con sus sistemas. Incluyó consulta de registros DNS públicos, análisis de certificados emitidos mediante fuentes de Certificate Transparency, revisión de registros históricos de infraestructura, búsqueda de referencias cruzadas en motores de búsqueda y repositorios públicos, y análisis de metadatos en documentos publicados por la organización. Herramientas utilizadas en esta fase: dig y herramientas de consulta DNS, crt.sh para análisis de certificados, y utilidades de búsqueda sobre fuentes públicas.

Fase 2 — Enumeración de activos. A partir del inventario preliminar construido en la fase anterior, se ejecutó descubrimiento activo de subdominios y validación de resolución DNS sobre los activos identificados. Se utilizaron amass y subfinder para enumeración de subdominios, combinando técnicas pasivas (consulta de fuentes públicas) y activas (resolución DNS y técnicas de descubrimiento por

diccionario). La validación de cada activo incluyó verificación de respuesta HTTP/HTTPS y captura de información básica de identificación.

Fase 3 — Análisis de servicios y configuraciones. Sobre los activos validados, se realizó escaneo controlado de puertos y servicios utilizando nmap en modalidad no intrusiva, con perfiles de escaneo ajustados para minimizar impacto operativo sobre el entorno auditado. La inspección se extendió a respuestas HTTP (headers, códigos de estado, cuerpos de respuesta en rutas conocidas), certificados TLS, banners de servicios y cualquier información técnica inferible de la interacción con los endpoints. Para el análisis de configuraciones web se utilizaron herramientas de inspección de cabeceras y testssl.sh para evaluación de configuración TLS.

Fase 4 — Correlación y análisis. Los datos obtenidos en las fases anteriores fueron integrados en un inventario unificado y analizados en conjunto, con el objeto de identificar patrones de exposición, agrupaciones de activos con configuraciones similares, indicios de segmentación de entornos y desalineaciones entre la exposición técnica observada y la función operativa declarada de los activos.

Condiciones y limitaciones del análisis

Durante toda la ejecución se evitó cualquier acción intrusiva o disruptiva. No se realizaron intentos de autenticación, pruebas de explotación, envío de cargas maliciosas ni acciones que pudieran afectar la disponibilidad de los servicios analizados. La ejecución de los escaneos activos se coordinó con el cliente en términos de ventana temporal, aunque no se notificó al equipo operativo para preservar la validez del ejercicio como simulación de reconocimiento externo.

Se identificaron algunas limitaciones puntuales durante la enumeración. Ciertos activos presentaban mecanismos de rate limiting o respuestas filtradas por geolocalización, lo que condicionó la exhaustividad del descubrimiento en segmentos específicos del perímetro. En consecuencia, los resultados deben interpretarse como una representación consistente pero no exhaustiva de la superficie real: la exposición efectiva podría ser mayor que la documentada en este informe.

4. Hallazgos

Esta sección documenta los hallazgos identificados durante la auditoría. Cada uno se presenta con una descripción técnica, la evidencia sanitizada cuando corresponde, las implicancias de riesgo asociadas y la referencia a la recomendación vinculada en la sección 6.

Criterio de severidad

Los hallazgos se clasifican en cuatro niveles (crítico, alto, medio, bajo) según la combinación de dos factores: facilidad de explotación por parte de un tercero no autorizado y magnitud del impacto potencial sobre la confidencialidad, integridad o disponibilidad de los activos de la organización. La valoración considera el contexto operativo del entorno auditado y no se apoya exclusivamente en puntuaciones CVSS de vulnerabilidades individuales, dado que el foco del trabajo es la exposición agregada y no la explotación de vulnerabilidades específicas.

Resumen de hallazgos

H-01	Inventario de activos publicados desalineado con la operación actual	Medio

H-02	Interfaz de correo web accesible sin segundo factor de autenticación	Alto
H-03	Panel administrativo accesible en puerto no estándar sin restricción por origen	Alto
H-04	Fugas de información en respuestas de servicios y configuración deficiente de correo	Medio

H-01 — Inventario de activos publicados desalineado con la operación actual

Severidad: Medio

Categoría: Gestión de superficie de exposición

Descripción

El proceso de enumeración de activos identificó un conjunto de subdominios y servicios publicados cuya función operativa no pudo asociarse con la actividad corriente de la organización. Varios de estos activos presentaban características consistentes con entornos heredados: versiones de software anteriores a las desplegadas en los activos principales, certificados TLS emitidos con más de dieciocho meses de antigüedad y sin rotación aparente, y contenido referido a productos o servicios discontinuados según la propia comunicación pública de la organización.

En particular, se identificaron activos correspondientes a lo que se interpreta como un entorno web anterior, un portal auxiliar vinculado a una integración con un proveedor externo aparentemente en desuso, y un subdominio con nomenclatura asociada a pruebas o desarrollo que respondía a peticiones HTTP con código 200 y contenido aplicacional activo.

Ninguno de estos activos aparecía referenciado en los canales oficiales de la organización.

Evidencia

El siguiente extracto ilustra el tipo de correlación que permitió identificar la desalineación. Los identificadores han sido sustituidos por placeholders, pero la estructura y el contenido informativo se preservan.

Consulta a crt.sh sobre el dominio principal (últimos 24 meses):

- www.[dominio].[tld] emitido: reciente CA: Let's Encrypt
- portal.[dominio].[tld] emitido: reciente CA: Let's Encrypt
- old.[dominio].[tld] emitido: 19 meses CA: Let's Encrypt [sin renovación posterior]
- dev-crm.[dominio].[tld] emitido: 14 meses CA: Let's Encrypt
- proveedor-x.[dominio].[tld] emitido: 22 meses CA: Sectigo [sin renovación posterior]

Validación DNS sobre los activos con certificados no renovados:

- old.[dominio].[tld] → resuelve, responde HTTP 200
- proveedor-x.[dominio].[tld] → resuelve, responde HTTP 200

Verificación de referencias públicas:

- old.[dominio].[tld] → no referenciado en sitio principal

- dev-crm.[dominio].[tld] → no referenciado en sitio principal
- proveedor-x.[dominio].[tld] → no referenciado; proveedor mencionado como ex-partner en nota de prensa del año anterior

La lectura cruzada de estos elementos permite inferir con razonable seguridad que se trata de activos heredados que permanecen publicados sin una gestión activa. Esta inferencia se realizó exclusivamente con información pública, sin interacción intrusiva con los sistemas.

Implicancias de riesgo

Los activos heredados presentan un perfil de riesgo característico. En primer lugar, tienden a quedar fuera de los ciclos regulares de actualización y aplicación de parches, lo que incrementa la probabilidad de que contengan vulnerabilidades conocidas no remediadas. En segundo lugar, al no estar asociados a funciones operativas activas, es menos probable que cualquier actividad anómala sobre ellos sea detectada en tiempo útil. En tercer lugar, su existencia amplía la superficie sobre la que un tercero puede construir conocimiento del entorno sin generar alertas.

Desde el punto de vista del inventario, la presencia de estos activos indica que el criterio de gestión del perímetro público no contempla la despublicación sistemática de componentes que dejan de tener función operativa.

Recomendación asociada: R-01 (despublicación de activos sin función operativa) y R-09 (inventario centralizado de activos publicados).

H-02 — Interfaz de correo web accesible sin segundo factor de autenticación

Severidad: Alto

Categoría: Autenticación y control de acceso

Descripción

Durante la enumeración de servicios se identificó una interfaz de correo electrónico web accesible desde internet sin restricciones de origen. El servicio responde en el puerto HTTPS estándar sobre un subdominio con nomenclatura convencional para este tipo de aplicaciones y presenta una página de autenticación basada en usuario y contraseña como único factor.

La inspección de la respuesta HTTP y del contenido de la página de autenticación permitió identificar la aplicación y su versión aproximada. La versión inferida correspondía a una rama del producto que, al momento del análisis, acumulaba varias actualizaciones de seguridad publicadas por el proveedor sin que se observaran indicios de aplicación en el servicio expuesto.

Adicionalmente, no se detectaron mecanismos visibles de limitación de intentos de autenticación dentro de los márgenes del análisis no intrusivo.

La exposición de este servicio es particularmente relevante porque la interfaz de correo web constituye, en la práctica, una puerta de entrada al ecosistema de identidad de la organización.

Evidencia

Respuesta HTTP sobre el endpoint de autenticación, con identificadores sustituidos por placeholders:

```
$ curl -sI https://mail.[dominio].[tld]/
HTTP/1.1 200 OK
Date: [fecha sanitizada]
Server: Apache/2.4.x
X-Powered-By: PHP/7.4.x
Set-Cookie: roundcube_sessid=[...]; path=/; HttpOnly
Set-Cookie: roundcube_sessauth=[...]; path=/; HttpOnly
Content-Type: text/html; charset=UTF-8
[fragmento del cuerpo de respuesta]
<meta name="generator" content="Roundcube Webmail [versión]">
<title>[organización] :: Webmail</title>
```

Observaciones derivadas del fragmento anterior:

- El header Server revela la familia y rama mayor del servidor web.
- El header X-Powered-By expone la versión del intérprete PHP, que al momento del análisis correspondía a una rama sin soporte activo del proveedor.
- La etiqueta meta generator en el cuerpo de la respuesta identifica explícitamente la aplicación y su versión.
- Las cookies de sesión se establecen con el atributo HttpOnly pero, en el fragmento observado, sin Secure ni SameSite.

Análisis complementario de la configuración TLS del servicio (extracto de testssl.sh, reformateado): Protocolos negociables: TLS 1.2, TLS 1.3

- Protocolos obsoletos: TLS 1.0 y 1.1 deshabilitados
- Cifrados débiles: no detectados en la negociación inicial
- HSTS: no presente en la respuesta del servicio

La configuración TLS es aceptable en cuanto a protocolos y cifrados, aunque la ausencia del header Strict-Transport-Security constituye una omisión de hardening.

No se intentó autenticación contra el servicio en ningún momento del análisis. Toda la información documentada se obtuvo a partir de respuestas públicas del servidor, sin envío de credenciales.

Implicancias de riesgo

La combinación de factores observada configura un escenario de exposición elevada por tres motivos.

En primer lugar, por la naturaleza del servicio. Una interfaz de correo web es un objetivo de alto valor, ya que una credencial válida puede dar acceso no solo al buzón del usuario, sino también a otros servicios corporativos que comparten el mismo directorio de autenticación.

En segundo lugar, por la ausencia de segundo factor. La exposición pública de una interfaz de autenticación basada exclusivamente en usuario y contraseña constituye una debilidad estructural, especialmente en servicios de acceso remoto con información sensible asociada.

En tercer lugar, por la inferabilidad de la versión. La exposición explícita del producto y su versión, combinada con la aparente desactualización respecto del ciclo de parches del proveedor, reduce significativamente el esfuerzo necesario para identificar vulnerabilidades potencialmente aplicables.

Desde el punto de vista del negocio, un compromiso de este componente puede tener implicancias relevantes en materia de protección de datos personales y continuidad operativa. Esta consideración se retoma en la sección 7.

Recomendación asociada: R-02 (implementación de segundo factor de autenticación sobre servicios de acceso remoto), R-03 (restricción de acceso por origen sobre interfaces no destinadas a público general) y R-06 (revisión y endurecimiento de headers de respuesta en servicios expuestos).

H-03 — Panel administrativo accesible en puerto no estándar sin restricción por origen

Severidad: Alto

Categoría: Exposición de interfaces de administración

Descripción

El escaneo de servicios sobre uno de los activos identificados durante la enumeración reveló la presencia de una interfaz de administración accesible desde internet en un puerto no estándar. El servicio respondía sin requerir autenticación previa en la capa de red ni presentaba indicios de filtrado por origen: peticiones desde distintas fuentes utilizadas durante el análisis obtuvieron respuesta consistente, lo que permite concluir razonablemente que el acceso estaba abierto desde internet.

La interfaz corresponde a un panel de gestión de base de datos basado en navegador, desplegado sobre el mismo activo que aloja uno de los servicios web de la organización. El análisis de las respuestas del servicio permitió identificar la aplicación y estimar su rama de versión. La versión inferida correspondía a una publicación anterior a varias actualizaciones de seguridad del proveedor, sin indicios de aplicación reciente de parches.

La coexistencia de un servicio web de cara al público y una interfaz administrativa sobre el mismo activo, sin segmentación de red ni restricción diferencial de acceso, constituye un patrón de configuración desfavorable.

Evidencia

Extracto del escaneo de puertos sobre el activo, con identificadores sustituidos:

```
$ nmap -sS -sV -Pn -p- --min-rate 500 [ip-sanitizada]
Nmap scan report for [activo].[dominio].[tld] ([ip-sanitizada])
Host is up (0.034s latency).
Not shown: 65531 filtered tcp ports
PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 8.x (protocol 2.0)
80/tcp open http Apache httpd 2.4.x
443/tcp open http Apache httpd 2.4.x
8080/tcp open http Apache httpd 2.4.x
```

El puerto 8080 no estaba referenciado en ningún canal oficial de la organización y no formaba parte del conjunto de servicios publicados esperables para la función operativa del activo. La inspección manual del puerto reveló la naturaleza del servicio:

```
$ curl -sI http://[activo].[dominio].[tld]:8080/
HTTP/1.1 200 OK
Date: [fecha sanitizada]
Server: Apache/2.4.x
Set-Cookie: phpMyAdmin=[...]; path=/; HttpOnly
X-Frame-Options: DENY
Content-Type: text/html; charset=utf-8
[fragmento del cuerpo de respuesta]
<title>phpMyAdmin</title> <link rel="icon" href="favicon.ico" type="image/x-icon"> <input
type="hidden" name="set_session" value="[...]">
```

La página presentada correspondía a la pantalla de autenticación estándar del producto. El análisis de recursos estáticos referenciados en la respuesta permitió acotar la rama de versión con precisión suficiente para contrastarla con el registro público de vulnerabilidades del proveedor.

Validación de la ausencia de restricción por origen mediante peticiones desde distintos puntos de salida utilizados durante el análisis:

- Origen A → HTTP 200 (acceso permitido)
- Origen B → HTTP 200 (acceso permitido)
- Origen C → HTTP 200 (acceso permitido)

Las tres consultas devolvieron respuesta equivalente sin observarse mecanismo de limitación basado en dirección de origen, geolocalización o rango de red conocido. No se intentó autenticación contra el servicio en ninguno de los casos.

Implicancias de riesgo

Las interfaces administrativas publicadas en internet sin restricción de origen constituyen un vector de exposición relevante. Son fácilmente detectables mediante procesos automatizados de reconocimiento. Este tipo de herramienta concentra privilegios elevados por diseño, dado que su función es administrar directamente los motores de base de datos.

En este caso, la combinación de exposición pública, ausencia de restricción por origen y aparente desactualización del componente incrementa la criticidad del hallazgo. Un eventual acceso exitoso sobre este tipo de interfaz podría habilitar, según el nivel de privilegios comprometido, lectura o modificación del contenido de las bases gestionadas y otras acciones de alto impacto sobre el entorno.

Desde una perspectiva de gestión, la presencia de este servicio sugiere una publicación no revisada o una excepción operativa que permaneció expuesta más tiempo del necesario.

Recomendación asociada: R-01 (despublicación de activos sin función operativa), R-03 (restricción de acceso por origen sobre interfaces no destinadas a público general) y R-04 (separación de planos de datos y administración en activos publicados).

H-04 — Fugas de información en respuestas de servicios y configuración deficiente de correo

Severidad: Medio

Categoría: Higiene de configuración y fuga de información

Descripción

Durante el análisis de los servicios publicados se observaron múltiples configuraciones que, sin representar por sí mismas una vulnerabilidad explotable en sentido estricto, contribuyen de forma acumulativa a facilitar tareas de reconocimiento y, en el caso específico de la configuración de correo electrónico, habilitan un vector de abuso relevante sobre la identidad corporativa del dominio.

El hallazgo agrupa dos categorías de observaciones. La primera corresponde a fugas de información en respuestas de servicios HTTP: headers que exponen versiones de software, mensajes de error que revelan rutas internas del sistema de archivos y componentes del stack aplicacional, y metadatos embebidos en respuestas que permiten identificar frameworks y sus versiones. La segunda corresponde a deficiencias en la configuración de los registros DNS asociados al dominio corporativo, concretamente en los mecanismos estandarizados de autenticación de correo electrónico (SPF, DKIM y DMARC).

Ambas categorías comparten un perfil característico: ninguno de los elementos individuales constituye por sí mismo un riesgo elevado, pero su presencia conjunta y la facilidad con la que son detectables por herramientas automatizadas los convierten en indicadores de que el entorno no ha sido sometido a un proceso sistemático de endurecimiento.

Evidencia

Fuga de información en respuestas HTTP. Extracto representativo de headers observados en varios de los servicios web analizados:

```
Server: Apache/2.4.x (Debian)
X-Powered-By: PHP/7.4.x
X-Generator: Drupal [versión]
```

En uno de los activos, la petición a una ruta inexistente devolvió un mensaje de error del framework en modo detallado:

```
HTTP/1.1 500 Internal Server Error
Content-Type: text/html; charset=UTF-8

Whoops\ErrorException in /var/www/[ruta-sanitizada]/vendor/[...]/File.php line [...]
Stack trace:
#0 /var/www/[ruta-sanitizada]/app/Http/Controllers/[...]
#1 /var/www/[ruta-sanitizada]/vendor/[...]
```

La respuesta revela la ruta absoluta de la instalación en el servidor, la estructura de directorios de la aplicación, el uso de un gestor de dependencias específico y la presencia de un manejador de errores configurado en modo desarrollo sobre un entorno que, por el resto de sus características, corresponde a producción.

Configuración de autenticación de correo electrónico. Consulta directa de los registros DNS asociados al dominio corporativo:

```
$ dig +short TXT [dominio].[tld]

"v=spf1 include:_spf.[proveedor].com ~all"
```

```
$ dig +short TXT _dmarc.[dominio].[tld]
"v=DMARC1; p=none; rua=mailto:[...]"

$ dig +short TXT [selector]._domainkey.[dominio].[tld]
(sin respuesta)
```

Observaciones sobre los registros anteriores:

- El registro SPF termina en ~all (softfail) en lugar de -all (hardfail).
- El registro DMARC está publicado con política p=none.
- No se obtuvo respuesta a la consulta del selector DKIM más probable, lo que sugiere que DKIM no está desplegado o que lo está bajo un selector no convencional que no pudo identificarse desde fuentes públicas.

La combinación de las tres observaciones describe un dominio cuya configuración técnica no implementa de forma efectiva los controles estandarizados contra la suplantación de identidad en correo electrónico.

Implicancias de riesgo

Las dos categorías del hallazgo tienen implicancias distintas.

Sobre las fugas de información en respuestas HTTP, el impacto directo es limitado, pero reducen significativamente el esfuerzo de reconocimiento para un tercero y permiten dirigir con mayor precisión cualquier intento posterior de explotación o enumeración.

Sobre la configuración de correo electrónico, el impacto es diferente: la ausencia de controles efectivos contra suplantación facilita escenarios de phishing dirigido, fraude por suplantación de identidad comercial y campañas de ingeniería social apoyadas en la credibilidad del dominio legítimo.

A diferencia de otros hallazgos del informe, aquí el riesgo puede proyectarse también sobre terceros que mantienen relaciones con la organización, con potencial impacto reputacional y eventual proyección jurídica para el titular del dominio.

Recomendación asociada: R-06 (revisión y endurecimiento de headers de respuesta en servicios expuestos), R-07 (configuración del entorno de ejecución en modo producción sobre aplicaciones publicadas) y R-08 (implementación efectiva de SPF, DKIM y DMARC con política de aplicación).

5. Evaluación de Riesgo

Los hallazgos individuales documentados en la sección anterior describen aspectos específicos de la exposición. Esta sección sintetiza el riesgo desde una perspectiva agregada, considerando la interacción entre los hallazgos y los escenarios concretos que su combinación habilita.

Riesgo agregado: medio-alto. Ningún hallazgo por sí solo configura una situación de compromiso inminente. La severidad del conjunto no deriva de un punto crítico aislado, sino de la forma en que los hallazgos se complementan entre sí: el inventario desalineado (H-01) facilita el descubrimiento del panel administrativo expuesto (H-03); las fugas de información en respuestas HTTP (H-04) reducen el esfuerzo necesario para identificar versiones potencialmente vulnerables en los servicios publicados,

incluido el webmail sin segundo factor (H-02); y la configuración deficiente de correo (H-04) habilita escenarios de ingeniería social que pueden dirigirse a las credenciales del propio webmail. Cada hallazgo, considerado de forma aislada, presenta un riesgo menor que el que efectivamente aporta en este conjunto.

Escenarios plausibles de incidente

La combinación observada habilita tres escenarios concretos que conviene explicitar, ya que son los que el trabajo posterior de remediación debe priorizar.

El primer escenario es el compromiso de una credencial de correo corporativo por fuerza bruta o por phishing apoyado en la suplantación del propio dominio. El vector inicial es el servicio de webmail accesible sin segundo factor; el elemento agravante es la capacidad de enviar correos creíbles desde direcciones del dominio legítimo, lo que permite construir pretextos convincentes sin necesidad de comprometer previamente ningún buzón. El impacto inmediato sería el acceso al buzón comprometido y a la información que contiene; el impacto derivado, el uso de ese buzón como punto de apoyo para compromisos adicionales dentro del ecosistema de identidad corporativa.

El segundo escenario es el descubrimiento y eventual explotación de la interfaz administrativa expuesta por parte de un actor oportunista. Este escenario no requiere conocimiento previo de la organización ni una intención dirigida: la combinación de exposición pública, ausencia de restricción por origen y aparente desactualización del componente lo convierte en un objetivo visible para procesos automatizados de reconocimiento y potencial explotación.

El tercer escenario es la utilización del dominio corporativo como vehículo de ataques contra terceros que mantienen relaciones con la organización. Este escenario tiene la particularidad de que la organización auditada puede no sufrir un incidente directo y, aun así, ser el origen técnico de una acción que afecte a un cliente, proveedor o socio comercial. Las consecuencias, incluidas las reputacionales y eventualmente contractuales, pueden recaer parcialmente sobre el titular del dominio, aunque su infraestructura no haya sido comprometida.

Distribución temporal del riesgo

El riesgo asociado a los hallazgos no se distribuye de forma uniforme en el tiempo. Los escenarios primero y segundo son sensibles a ventana de oportunidad: cuanto más tiempo permanezcan las condiciones actuales, mayor es la probabilidad de que sean aprovechadas. El tercer escenario tiene una dinámica distinta: la capacidad de suplantación existe desde el momento en que los registros DNS están deficientemente configurados y persiste mientras esa condición no se corrija.

Esta distribución informa la priorización de las recomendaciones en la sección siguiente: las medidas que cierran ventanas de oportunidad deben ejecutarse con mayor urgencia que aquellas orientadas a corregir condiciones estructurales o persistentes.

Nota sobre interpretación de la ausencia de incidentes

Durante el período de análisis no se identificaron indicadores de compromiso activo. Esta observación es relevante, pero debe interpretarse con cautela: la auditoría se limitó a observación externa y no incluyó análisis de registros internos, por lo que un compromiso ya materializado, pero no visible desde el exterior no habría sido detectable con la metodología aplicada. La ausencia de indicadores

externos no constituye evidencia de ausencia de compromiso, sino únicamente ausencia de indicadores externos detectables.

Con esa salvedad, el escenario actual debe entenderse como una ventana de mitigación previa a una eventual explotación, no como un estado estable.

6. Recomendaciones

Las recomendaciones se organizan en dos niveles. El primero comprende acciones de remediación directa, orientadas a reducir de forma inmediata las condiciones de exposición identificadas en los hallazgos de la sección 4. El segundo comprende medidas de gestión y gobernanza, orientadas a sostener en el tiempo el estado remediado y a evitar la reaparición de condiciones equivalentes.

Cada recomendación del primer nivel remite explícitamente al hallazgo o hallazgos que la motivan. Las recomendaciones del segundo nivel no se asocian a hallazgos individuales, ya que su alcance es sistémico: atienden las condiciones de entorno que hicieron posible el perfil de exposición observado en su conjunto.

Nivel 1 — Remediación directa

R-01. Despublicación de activos sin función operativa actual. Revisar los activos identificados en H-01 y determinar, para cada uno, si corresponde una función operativa vigente. Los activos sin función identificable deben ser despublicados mediante eliminación de los registros DNS correspondientes y desactivación de los servicios asociados en los sistemas que los alojan. Para los activos cuya eliminación requiera verificación adicional, restringir el acceso por origen hasta completar la revisión. *Relacionado con H-01 y H-03. Esfuerzo estimado: bajo. Horizonte: inmediato.*

R-02. Implementación de segundo factor de autenticación sobre la interfaz de correo web. Habilitar un mecanismo de segundo factor sobre el servicio documentado en H-02. En caso de que la gestión del componente corresponda a un proveedor externo, formalizar el requerimiento como condición de servicio. Mientras el segundo factor no esté operativo, valorar la restricción por origen como medida transitoria para los usuarios cuya operación lo permita. Relacionado con H-02. *Esfuerzo estimado: medio. Horizonte: inmediato.*

R-03. Restricción por origen sobre interfaces administrativas y paneles de gestión. Retirar de la exposición pública directa los paneles de administración identificados en H-03 y cualquier otra interfaz cuya función no requiera acceso desde internet no restringido. Las vías recomendadas, en orden de preferencia, son: publicación exclusivamente en redes internas con acceso vía VPN; filtrado por origen sobre un conjunto acotado de direcciones IP operativas conocidas; o, como medida transitoria, introducción de una capa de autenticación adicional por delante de la aplicación hasta implementar una solución estructural. Relacionado con H-02 y H-03. *Esfuerzo estimado: medio. Horizonte: inmediato.*

R-04. Separación de planos de datos y administración en activos publicados. Revisar la coexistencia, sobre un mismo activo, de servicios destinados al público general y de componentes de administración o gestión. Donde exista coexistencia, planificar la separación de ambos planos en activos distintos o, si la separación física no es viable a corto plazo, implementar segmentación lógica mediante virtual hosts, puertos dedicados y políticas de acceso diferenciadas. *Relacionado con H-03. Esfuerzo estimado: medio-alto. Horizonte: corto plazo.*

R-05. Actualización de componentes con versiones desactualizadas. Planificar la actualización de los componentes de software identificados con versiones fuera del ciclo de soporte vigente del proveedor, con especial atención a los servicios cuyo análisis reveló exposición de versión en respuestas HTTP (ver H-02 y H-04). La actualización debe incluir tanto componentes del nivel aplicacional como del nivel de plataforma cuyo ciclo de soporte haya finalizado o se encuentre próximo a finalizar. Relacionado con H-02, H-03 y H-04. *Esfuerzo estimado: medio. Horizonte: corto plazo.*

R-06. Revisión y endurecimiento de headers de respuesta en servicios expuestos. Configurar los servicios web publicados para suprimir o minimizar la información revelada en los headers de respuesta. Como referencia, los headers Server y X-Powered-By deben reducirse a información mínima o eliminarse; además, deben añadirse los headers de seguridad ausentes con valores acordes a la funcionalidad de cada servicio. La revisión debe incluir también los atributos de las cookies de sesión (Secure, HttpOnly, SameSite). Relacionado con H-02 y H-04. *Esfuerzo estimado: bajo. Horizonte: inmediato.*

R-07. Configuración de entornos de ejecución en modo producción. Revisar la configuración de los frameworks y entornos de ejecución de las aplicaciones publicadas para garantizar que los manejadores de errores operen en modo producción, sin exposición de trazas de pila, rutas del sistema de archivos o información de depuración. Esta revisión debe extenderse a cualquier componente del stack que distinga entre modo desarrollo y modo producción (frameworks web, gestores de dependencias, sistemas de logging accesibles desde el frontend). *Relacionado con H-04. Esfuerzo estimado: bajo. Horizonte: inmediato.*

R-08. Configuración efectiva de autenticación de correo electrónico. Implementar o corregir los registros SPF, DKIM y DMARC asociados al dominio corporativo con el objetivo de reducir de forma efectiva la posibilidad de suplantación del dominio en correo saliente. El proceso recomendado sigue una secuencia progresiva: desplegar DKIM, ajustar el registro SPF y endurecer gradualmente la política DMARC, previa verificación de que no existan fuentes legítimas de correo afectadas por el cambio. *Relacionado con H-04. Esfuerzo estimado: bajo-medio. Horizonte: corto plazo.*

Nivel 2 — Gestión y gobernanza

R-09. Inventario centralizado de activos publicados. Establecer y mantener un inventario único de los activos de la organización accesibles desde internet, incluyendo dominios, subdominios, direcciones IP, servicios publicados y responsable funcional asignado. El inventario debe actualizarse ante cada alta, baja o modificación de un activo expuesto, y revisarse periódicamente mediante procesos de descubrimiento análogos a los utilizados en esta auditoría, con el objeto de detectar divergencias entre el inventario declarado y el estado observable.

R-10. Criterios formales de publicación de servicios. Definir un conjunto de criterios que deban cumplirse para que un servicio sea publicado en internet, incluyendo justificación de la necesidad operativa, asignación de responsable, configuración mínima de hardening y previsión de baja cuando corresponda. Los criterios deben ser conocidos por los equipos que gestionan infraestructura y aplicarse como requisito previo a cualquier publicación.

R-11. Monitorización de la superficie expuesta. Incorporar como práctica regular la monitorización de la superficie de exposición mediante herramientas de descubrimiento externo y seguimiento de certificados, DNS y menciones del dominio en fuentes públicas. La monitorización debe generar alertas ante la aparición de activos no declarados, cambios en el estado de servicios publicados o indicios de suplantación del dominio corporativo.

R-12. Revisiones periódicas de exposición digital. Incorporar auditorías de exposición externa como proceso recurrente, con una periodicidad mínima anual y complementaria ante cambios significativos de infraestructura. La periodicidad puede ajustarse en función del dinamismo operativo de la organización y del resultado de las revisiones previas.

R-13. Integración de la gestión de exposición en el marco de gobierno del riesgo tecnológico. Las medidas anteriores deben integrarse en el modelo de gobernanza del riesgo tecnológico de la organización, con asignación formal de responsabilidades, reporte periódico a las instancias de decisión correspondientes y vinculación con los procesos de gestión de incidentes y continuidad operativa. La gestión de la superficie expuesta no debería tratarse como una función técnica aislada, sino como un componente del sistema de control interno sobre el riesgo tecnológico de la organización.

7. Conclusión

La auditoría identificó un conjunto de condiciones de exposición que, consideradas en su conjunto, configuran un escenario de riesgo medio-alto para la organización. El riesgo no se concentra en un hallazgo crítico aislado, sino en la combinación de exposiciones de severidad individual moderada que, al interactuar, reducen el esfuerzo requerido por un tercero para comprender el entorno y habilitan escenarios de incidente concretos y plausibles en el corto plazo.

Los hallazgos describen, en esencia, un entorno en el que la superficie expuesta creció de forma acumulativa sin estar sujeta a un proceso sistemático de gestión, revisión y depuración. Este patrón no es excepcional: suele aparecer en organizaciones donde la infraestructura se sostiene con recursos operativos ajustados y donde la responsabilidad sobre la exposición pública no está formalmente asignada. La consecuencia es la observada en este informe: activos heredados que permanecen publicados, servicios expuestos que no fueron revisados tras su despliegue inicial y configuraciones por defecto que atraviesan los ciclos operativos sin ser cuestionadas.

Las medidas de remediación directa recomendadas en la sección 6 son técnicamente accesibles y pueden ejecutarse en un horizonte corto sin requerir inversiones significativas. Su impacto sobre el perfil de riesgo de la organización es alto en relación con el esfuerzo necesario. Las medidas estructurales, por su parte, requieren asignación explícita de responsabilidades y revisión del modelo de gestión de infraestructura publicada, pero su valor reside en la capacidad de sostener el estado remediado a lo largo del tiempo y evitar la recurrencia de condiciones equivalentes.

Implicancias regulatorias

Más allá de la dimensión técnica, varios de los hallazgos tienen proyección en el marco de cumplimiento normativo europeo aplicable a la organización. Este apartado no constituye asesoramiento jurídico formal ni sustituye el análisis que corresponde a las funciones de cumplimiento y asesoría legal, pero señala puntos de contacto que conviene considerar.

En materia de protección de datos personales, el Reglamento General de Protección de Datos establece la obligación de aplicar medidas técnicas y organizativas apropiadas al nivel de riesgo, y prevé deberes específicos de notificación en caso de violaciones de seguridad. Los hallazgos relativos a la exposición del servicio de webmail (H-02), al panel administrativo de gestión de bases de datos (H-03) y a la

configuración deficiente de autenticación de correo (H-04) pueden incidir directamente en ese marco, en la medida en que los servicios afectados procesen o den acceso a datos personales.

En materia de ciberseguridad, la Directiva (UE) 2022/2555 (NIS2) refuerza las obligaciones de gestión de riesgos, medidas técnicas y organizativas y notificación de incidentes para entidades esenciales e importantes. En España, la transposición nacional ha sido tratada como una prioridad institucional, por lo que conviene formular esta parte del informe con cautela y sin atarla a una fecha cerrada de entrada en vigor si el documento va a circular como pieza de portfolio.

En ese contexto, las condiciones observadas en esta auditoría, como la ausencia de un inventario gestionado de activos publicados, la falta de criterios formales de publicación de servicios y la inexistencia de una monitorización sistemática de la superficie expuesta, son consistentes con deficiencias de gestión del riesgo que los marcos regulatorios europeos actuales buscan corregir. La remediación estructural propuesta en las recomendaciones R-09 a R-13 no solo reduce la exposición técnica, sino que también fortalece capacidades de gobernanza y trazabilidad alineadas con ese enfoque.

Cierre

La exposición digital de una organización es una dimensión del riesgo tecnológico que combina aspectos técnicos, operativos, de gobernanza y de cumplimiento normativo. Tratarla exclusivamente como un problema técnico conduce a remediaciones puntuales que se deterioran con el tiempo; tratarla exclusivamente como un problema de gobernanza produce políticas sin aplicación real. El valor de una auditoría de exposición reside en tender un puente entre ambas dimensiones: traducir observaciones técnicas en decisiones de gestión y, en sentido inverso, anclar los procesos de gobernanza en las condiciones reales del entorno que pretenden gobernar.

Las recomendaciones de este informe buscan aportar ese puente para el caso auditado. Su implementación corresponde a la organización, en los plazos y con las prioridades que su propio contexto operativo determine.

Sobre el autor

Informe elaborado por Mariano Enrique Torres Ponce, consultor independiente en riesgo tecnológico. Formación jurídica en derecho informático por la Universidad de Buenos Aires y más de veinte años de experiencia en infraestructura, fiabilidad de sistemas y ciberseguridad en entornos regulados, incluyendo el sector bancario en España, Argentina y Chile.